INTEREST PROTOCOL / SECURITY REVIEW RECORD

Blast launch stack

Astra security audit using Trail of Bits public skills

6 November 2026 · OpenAI Astra audit agent

Reviewed source	`d80f2834468ba798df66f36d01fd64eec9d4df91`
Requested scope	Admin · Core · Migrators · Vault · Launchpad · Presale
Security findings	**0 critical · 0 high · 0 medium · 0 low**
Informational findings	1 — superseded collection and venue-admission documentation
Executed verification	1,312 Move tests and 37 native PTB tests passed; detailed boundaries and qualifications follow.

AI-conducted review. This report applies pinned public Trail of Bits skills. It is not an audit performed or endorsed by Trail of Bits.

Repository edition: the reviewed source, original finding and verification results are preserved. Informational I-1 was open at review completion; its subsequent documentation remediation is recorded in `audits/README.md`. Supporting evidence is retained separately by Blast; local evidence references in the report are labels rather than public download links.

Original Markdown SHA-256:
`d5dcf22d239d2dc8a6ffafdf73cb3c9d35263910efa70f076a9c030c5fbea461`

Reviewed source: `d80f2834468ba798df66f36d01fd64eec9d4df91`, resolved from GitHub `main` on 6 November 2026 (Europe/Lisbon), then frozen. **Reviewer:** OpenAI Astra audit agent. **Methodology source:** Trail of Bits public skills, pinned to `470419e16f97e112d01fc32f4898aea1755015d9`. This is an AI-conducted review applying those instructions; it is **not an audit performed or endorsed by Trail of Bits**.

Result

No new actionable security vulnerability was confirmed at the reviewed SHA. There are **0 critical, 0 high, 0 medium and 0 low security findings**. One informational documentation finding is recorded below. Previously reported stale-version unpause and collection/compounding coupling are remediated in this source; the review did not carry historical findings forward as current defects.

The connected source review covered authority, custody, conserved value, rounding, replay, type/object identity, delayed administration, pause/version boundaries, upgrade and immutability liveness, same-PTB settlement, claims/refunds, and admitted external integrations. Existing automated checks and native integration results are detailed below. These results do not establish a production deployment's configuration or prove every admitted economic parameter combination safe.

Scope and publication posture

The six requested packages were reviewed as one protocol: `sui/admin`, `sui/core`, `sui/migrators`, `sui/vault`, `sui/launchpad`, and `sui/presale`. Reached `sui/partners` and irrevocable linear vesting in `sui/vesting` were included. The checkpoint-vesting sibling was inventoried but is not called by core payout and did not receive a body audit. Other products, SDKs, workers, frontend code, off-chain reward manifests and deployment operators are outside scope.

The frozen repository describes a **fresh seven-package lineage**, with no `Published.toml` for those seven packages. Admin, partners and core are intended to be published immutable; launchpad, presale, vault and migrators start compatible-upgradeable under generic administration. Vault immutability is a later, deliberate post-audit action. Published utility vesting is a separate immutable dependency. This is the repository's declared posture, not an assertion that any observed historical package ID is this source. Publication decision, vesting publication record.

The absence of a principal-withdrawal function does not make custody irrevocable while relevant upgrade authority remains. A vault upgrade requires migrator relinking; products do not import migrators. Incorrect compiled versions retain the documented upgrade-repair path, while immutability remains gated by the current version and package witness. This audit preserves those accepted decisions rather than recommending incompatible policy narrowing or restoring raw capability escape hatches.

Method and coverage

The canonical checkout was dirty and behind main. It was read only: no reset, checkout, clean, build or contract edit occurred there. An exact-commit `git archive` source snapshot and separate task-owned test copy were used. SHA256 source and native-binary records are in the verification bundle.

The six packages contain **54 production source files / 15,436 source lines**, including test-only helper sections. The eight-package lexical inventory contains **724 non-macro production function declarations, including 451 public/entry declarations**. Those counts include readers and constructors and are **not** a count of state-changing entry points or independently proved functions. Security-critical production bodies and their callers/callees were traced; event/error modules received schema/usage and static-gate review. See the precise file coverage, callable inventory, context dossier and its 18 focused function records. No claim is made that every declaration received a separate isolated-agent review.

Pass	Work and outcome
Context building	Delegated authority/value-flow dossier before prior-audit reading. Enumerated shared/owned objects, constructor restrictions, capabilities, type domains and lifecycle transitions.
Entry-point analysis	Included ordinary public Move functions reachable through PTBs, not only `entry`. Traced actual cap construction and live-ID checks. Read-only proof, witness, ticket, admission and price functions were explicitly included in the wider security pass. See authority map.
Sui standards	Read frozen repository `sui-move-review`, all four required sibling standards (architecture, source style, security, testing), their required references and the package-upgrade-posture reference. Applied accepted ADR amendments and unpublished/published boundaries.
Spec-to-code	Delegated eight requirement records against ADRs and current docs; independently refuted security interpretations of divergences. Report.
False-positive checks	Full source-to-sink and attacker-precondition review of constructor forgery, wrong-venue/reinitialization, stale release gates, delisting, seed-price and auto-LP claims. Refutations and accepted-risk distinctions in verification record.
Differential review	After the independent pass, examined recent #217, #219, #220 and #222 changes and historical findings against frozen source. Differential record.
Variant analysis	Used historical confirmed stale-unpause and missing construction/attachment venue-binding seeds; expanded to all current unpause wrappers, position attachments and sealed origin constructors. No unfixed security variant confirmed. Variant record.
Execution	Fresh-stack Move lint/tests, source/style/error gates, live and offline ABI checks, focused pause instruction coverage, and task-owned native PTB runs. Exact outcomes below.

The public ToB instructions target a Claude plugin runtime. That runtime and its schema-enforced slash commands were not installed. Codex delegation, sequential constrained analysis and saved evidence implement the workflows here. Context/spec checks used a delegated analyst and independent lead refutation; they did not spawn a fresh isolated process per each of the 724 functions or per every possible specification sentence. Deep FP tracing was delegated, with impact, devil's advocate and final gates performed by the lead. No native-plugin execution is claimed.

Pinned methodology: audit-context-building, entry-point-analyzer, spec-to-code-compliance, fp-check, variant-analysis, differential-review. Authoritative local Sui review.

Findings

I-1 — Superseded integration prose misstates collection and admission behavior

Severity: informational; documentation/integration correctness. **Confidence:** high. **Status:** open; no source or documentation fix applied by this audit.

Locations: `sui/migrators/DEPENDENCIES.md:52–56`, its Cetus route table at line 435, Bluefin route table at line 475, and `bluefin.move:138–139`. Related historical wording in ADR0137:133–138 says every migration checks both product and vault admissions.

Violated documentation invariant: current integration descriptions should identify which call performs maintenance and where admission is enforced. `collect_fees` now collects/splits only. It intentionally leaves auto-LP balances waiting for the separate `compound_auto_lp`, as accepted by ADR0134's amendment. Product venue lists gate creation/preparation; live vault registry admission remains checked at vault construction. Existing products retain their selected venue.

Realistic failure sequence: an integrator follows the stale route table and repeatedly submits only `collect_fees`, assuming the auto-LP route has already reinvested the collection. Collections succeed while auto-LP balances accumulate without the expected reinvestment. Similarly, an operator relying on the old blanket migration sentence may expect product delisting to stop an existing sale's migration; current product migration does not re-read that list. Product migration pause and vault registry controls remain the actual controls. No attacker privilege escalation, value theft or new collection lock is demonstrated.

Smallest remediation: align those paragraphs/comments with the accepted current two-call maintenance flow, and explicitly mark the old ADR sentence superseded by creation-only product admission semantics. Do not re-couple compounding to collection or add migration rechecks merely to match obsolete prose.

Missing regression: a named product-delisting scenario showing that existing sales retain their venue while new creation fails, if not already covered by an equivalent end-to-end test. Existing native tests deliberately append compounding; correct the prose directly rather than introducing a test that merely mirrors its wording. This is a report-only recommendation.

Security properties checked

- **Authority and upgrades:** live ACL cap-ID/role checks issue ephemeral witnesses; package publication requires OTW and same-package witness lineage. Generic administration retains native caps, binds receipts, delays exact upgrade digests, advances versions, and requires the package witness for release/immutability. All three current unpause wrappers check version first and include guarded treasury delay. No raw public witness constructor was found in production.
- **Custody and identity:** products own sealed treasury caps before preparation, and admitted venues borrow with exact issuer/venue admission. Product migration yields a no-ability handoff consumed by the stored venue in the same PTB. Vault construction fixes issuer/origin/venue, derived-object uniqueness, pool and permanent position key. Owner proofs bind both issuing witness and borrowed origin UID; receipts bind the exact vault. Position access and external pool-ID/type checks compose rather than relying on capability names.
- **Accounting and rounding:** fees use bounded BPS, widened intermediates and explicit rounding; apportionment conserves totals. Partner fee payment binds the fixed partner ID and takes its cut only from Blast's ledger. Presale allocation, overflow refund and cancellation preserve held balances; final claim handles residue. Launch target-capped buys, burns, fee claims and migration allocations were traced. Read-only curve, seed-price, Merkle and readiness calculations were treated as security-relevant.
- **Exits and replay:** sale lifecycle and creator-cap IDs constrain claims; claim/refund and owner exits are not arbitrarily paused. Holder rounds reserve balances at publication, bind vault/round/index/beneficiary/amounts into the leaf, enforce exact proof depth and a claim bitmap, and restore unclaimed funds only to the same vault. Vesting pays its fixed beneficiary with no product-created cancellation authority.

- **Integrations:** Cetus exact pair/order and reservation, Bluefin stored tiers and symbol constraints, seed rounding side selection, swap repayment/residual handling and vault fee routing were reviewed. Local interface `abort 0` bodies are not treated as venue behavior. Live ABI fingerprint verification and native committed-bytecode tests supply the integration evidence described next.

Verification results

Commands ran only in task-owned copies. Heavy commands held one of the shared host locks with a memory/PSI and disk-growth preflight, one Move compiler worker and one test thread. The canonical checkout and other tasks' test artifacts were not modified.

Check	Outcome
`bash scripts/test_admin_delay.sh admin partners core vault launchpad presale migrators`	PASS: warning-as-error Move lint and **1,259 tests**: 198 admin, 74 partners, 85 core, 127 vault, 448 launchpad, 287 presale, 40 migrators. Elapsed 1m49s; peak RSS 823MB.
`bash scripts/test_admin_delay.sh vesting`	PASS: 53 tests and warning-as-error lint. This includes utility tests beyond the reached linear path.
Fresh-stack source boundaries, admin checker self-tests; core/vault/partners standalone boundaries	PASS; individual logs retained.
`python3 scripts/check_move_style.py`	PASS: 241 first-party modules.
`python3 scripts/check_move_errors.py`	PASS: 338 first-party errors used/sequential/exact-abort oracles; 336 Move and 2 native mappings. A mapping check alone is not execution evidence.
`node sui/migrators/scripts/check_mainnet_abi.mjs --self-test`	PASS: 74/74 cases.
Same ABI checker, live official mainnet GraphQL	PASS: 5 packages, 11 modules, 38 functions, 14 structs; frozen local dependency graph validated. Read-only query, no transaction.
`MOVE_TEST_FILTER=pause_tests bash scripts/test_admin_delay.sh --coverage launchpad presale`	PASS: `launch_config::unpause` 43/43 instructions and `creation_policy::unpause` 20/20, both 100%. This is focused function coverage, not whole-audit coverage.
Native PTB integration suites	PASS: **37/37** across five suites: 12 atomic migration, 11 presale venue fork, 11 launch venue fork, 1 bootstrap and 2 allocation/maximum-shape measurements. Includes actual committed Cetus/Bluefin bytecode, both Cetus coin orders, rogue-venue re-share rejection, swaps/residuals/burns, near-equal seed rounding and pause/version rollback.

All five native suite processes exited 0; no task-owned compiler, test process, server or browser remains. Native executables were copied from a retained compatible build after comparing the full Rust harness tree/lockfile against the frozen target. They run from this task's crate directory, compile the target Move source into task-owned fixtures, and execute in-memory simulators with committed mainnet venue bytecode. This avoids an unnecessary new large Rust dependency build. Provenance and limitations.

Accepted risks and unproved hypotheses

These are not new vulnerability findings:

1. **Current-price auto-LP can be skimmed.** A caller may move pool price around permissionless compounding. The repository explicitly accepts this and recommends frequent compounding to keep each slice small. Separating collection prevents add-liquidity failure from blocking collection; it does not remove price risk. Accepted risk.
2. **Trusted administration and allocations.** Root grants, treasury redirection after notice, admitted integration code, delayed upgrades and holder-reward administrator allocation are trusted powers. Merkle proofs prove a published allocation, not the truth of beneficial ownership. Account-only beneficiary selection and custody exclusions remain off-chain responsibilities. Reward trust boundary.
3. **Venue operator liveness and missing migrator pause.** External pauses/version changes and Cetus pool-manager override can stop integrations. Migrators deliberately has no independent emergency pause. A delayed relink/upgrade remains the recovery mechanism where documented. An admitted malicious witness module remains inside the governance trust boundary.
4. **Seedability outside tested economic ranges remains a release obligation.** Default launch decimals are 6/9. Decimals 10 is admin-admissible and can fall outside presale's conservative factor-two seed margin, but its attainable amount ratio does not by itself violate the venues' hard price bound. No failing launch was demonstrated, so missing the presale assertion is not reported as a vulnerability. New precision/tier/extreme amount combinations need the adapter proof required by ADR0088 and DEPENDENCIES before admission.
5. **Adversarial Bluefin auto-LP completeness remains unproved.** Representative fork tests and pure helper grids are evidence, not exhaustive equivalence between local side estimates and all upstream states. The previous H-1 cannot lock fee collection after #217, because compounding is now separate. Failure of an untested add remains a maintenance-liveness hypothesis, not a demonstrated exploit.

Residual limitations and handoff

No live economic/dev-inspect matrix was executed against newly published production instances; the live check verifies package identities and ABI only. The fork uses committed mainnet bytecode/configuration at captured mainnet checkpoint 339033808 (2026-10-28T11:16:00.116Z), not every current/future operator configuration. No new complete Rust build or fork instruction-coverage instrumentation was run. Focused pause instruction coverage must not be extrapolated to all functions.

No formal verification, exhaustive fuzz campaign, gas-bound proof for every admitted maximum configuration, full independent DEX-implementation audit, live upgrade rehearsal, off-chain allocator audit or production custody attestation was performed. Manual source review and existing tests can miss defects. Native binary reuse has the provenance qualification above. The declared fresh lineage still requires its own external audit/quiet period under the accepted deployment plan; this report does not authorize publication or immutability.

The audit made no contract fix, commit, PR, public vulnerability issue, deployment or on-chain transaction. This report is prepared for the repository audit record. Supporting analyses and logs are retained separately by Blast. Address informational I-1 in normal documentation maintenance; retain the accepted-risk and release-matrix obligations when preparing a deployment.